

09 Access Control

09.01-09.02 Access Control and Authorization, Authentication protocols

Definitions

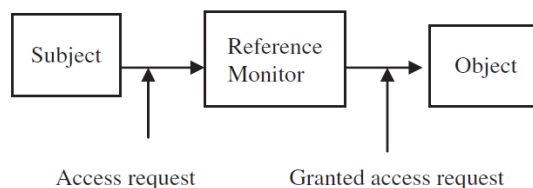
- *Access control is a process to determine “Who does what to what,” based on a policy.*
- Access control is restricting the access to a system or system resources based on something other than the identity of the user

Benefits of Access Control policy

- It focuses the organization's attention on security issues, and probably, this attention results in resource allocation toward system security.
- It helps in configuring appropriate security for each system resource based on role and importance in the system.
- It allows system auditing and testing.

Access Rights

- The permissions control user access to each system resource.
- Access control consists of four elements:
 - Subjects
 - Objects
 - Operations
 - A reference monitor



Access Control List

- A set of rules that specify certain restrictions is called an *access control list* (ACL).
- Subjects are system users and groups of users
- Objects are files and resources such as memory, printers, and scanners including computers in a network
- Reference monitor checks the rules to grant access to an object for a subject

Access modes and rights

- There are two access modes that can be specified to accessing an object:
 - Observe
 - Alter
- There are four access rights:
 - Execute
 - Read
 - Append
 - Write

Access modes and rights

	execute	append	read	write
observe			X	X
alter		X		X

- Access rights can be set individually on each system resource for each individual user and group.
- User access rights always take precedence over group access rights regardless of where the group rights are applied
- The owner of the resource sets the access rights to the resource.

Techniques and technologies

- Several control techniques and technologies have been developed to manage access rights for every user per every object:
 - access control matrix
 - capability tables
 - access control lists
 - role-based access control
 - rule-based access control
 - restricted interfaces
 - content-dependent access control

Techniques and technologies

- **Access Control Matrix**

- All the information needed for access control administration can be put into a matrix with rows representing the subjects or groups of subjects and columns representing the objects.
- The access that the subject or a group of subjects is permitted to the object is shown in the body of the matrix. access control matrix

Techniques and technologies

- **Access Control List**

- In the access control lists (ACLs), groups with access rights to an object are stored in association to the object.
- ACLs are very fitting for operating systems as they manage access to objects

Techniques and technologies

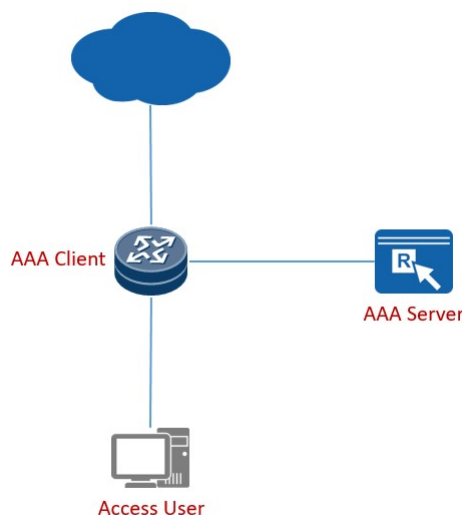
- **Access Control Capability**
 - A capability specifies that “the subject may do operation O on object X.”
 - Unlike the ACLs, capabilities access control storage between objects and subjects is based on the row in the access control matrix.
 - This means that every subject is given a capability, a forgeryproof token that specifies the subject’s access rights

AAA

- The "AAA" concept is the cornerstone of any systematic discipline of security (IT or otherwise). It is composed of:
 - **Authentication:** it confirms the identities of remote users accessing the network and determines whether the users are authorized.
 - **Authorization:** it assigns differentiated rights to authorize users to use specific services.
 - **Accounting:** it records all operations of a user during the network service process, to collect the network resource usage.

Access Rights

- AAA uses the client/server architecture.
- The access device on which an AAA client runs is usually called the network access server (NAS) that is responsible for user identity verification and user access management.
- An AAA server provides a collection of authentication, authorization, and accounting functions and is responsible for centralized user information management.

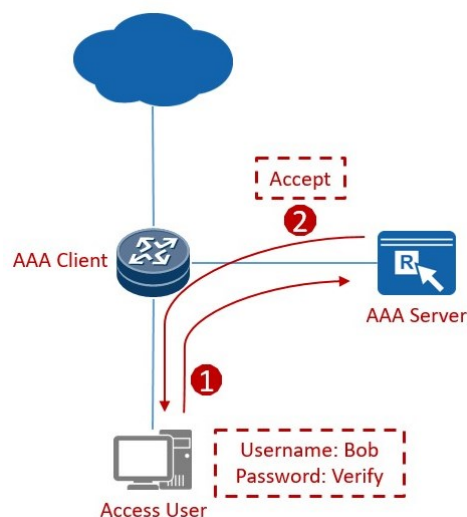


Authentication Methods

- The three types of authentication are commonly referred to as something you have (physical token), something you know (shared secret), and something you are (biometric measure).
- Forms of authentication include the following technologies:
 - **Biometrics.** These systems read some physical characteristic of the user, such as their fingerprint, facial features, retinal pattern, or voiceprint.
 - **Security devices.** These systems require use of a special-purpose hardware device that functions like a customized key to gain system access.
 - **Concentric-ring authentication.** These systems require users to clear additional authentication hurdles as they access increasingly sensitive information.

Authentication Process

- Suppose the access user sends the username and password to the AAA client to have itself authenticated.
- When receiving the username and password, the AAA client sends them to the AAA server to have this information verified.
- If the pair of username and password are correct, AAA will reply accept message to notify the AAA client that the accessing user is a legal user.
- Else, the AAA server will reply reject message to notify the AAA client the accessing user is an illegal user, as a result, the internet accessing traffic will be dropped by the AAA client.



Cryptography

- Cryptography can be grouped into four areas:
 - **Symmetric encryption:** Used to conceal the contents of blocks or streams of data of any size, including messages, files, encryption keys, and passwords.
 - **Asymmetric encryption:** Used to conceal small blocks of data, such as encryption keys and hash function values, which are used in digital signatures.
 - **Data integrity algorithms:** Used to protect blocks of data, such as messages, from alteration.
 - **Authentication protocols:** These are schemes based on the use of cryptographic algorithms designed to authenticate the identity of entities.

Symmetric encryption

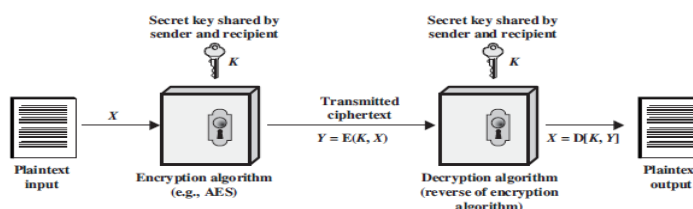
- Symmetric encryption is a form of cryptosystem in which encryption and decryption are performed using the same key.
- Symmetric encryption transforms plaintext into ciphertext using a secret key and an encryption algorithm. Using the same key and a decryption algorithm, the plaintext is recovered from the ciphertext.
- Possible attacks on an encryption algorithm are of two types:
 - cryptanalysis, based on properties of the encryption algorithm
 - brute-force, which involves trying all possible keys.

Symmetric encryption

- Traditional (precomputer) symmetric ciphers use substitution and/or transposition techniques.
- Substitution techniques map plaintext elements (characters, bits) into ciphertext elements. Transposition techniques systematically transpose the positions of plaintext elements.
- Rotor machines are sophisticated precomputer hardware devices that use substitution techniques.

Symmetric encryption

- The plaintext in input (original message) is coded with a key to become a ciphertext.
- The ciphertext will be decrypted with same key a destination, to have the plaintext again
- We do not need to keep the algorithm secret; we need to keep only the key secret.
- This feature of symmetric encryption is what makes it feasible for widespread use.

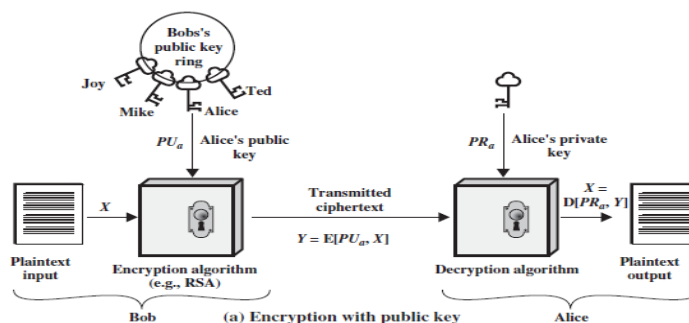


Asymmetric encryption

- Asymmetric encryption is a form of cryptosystem in which encryption and decryption are performed using different keys: public key and private key.
- Asymmetric encryption transforms plaintext into ciphertext using a one of two keys and an encryption algorithm.
- Using the paired key and a decryption algorithm, the plaintext is recovered from the ciphertext.
- Asymmetric encryption can be used for confidentiality, authentication, or both.

Asymmetric encryption

- Public-key algorithms are based on mathematical functions rather than on substitution and permutation.

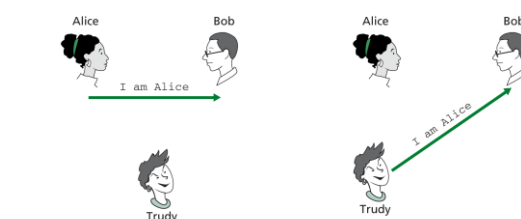


Message Authentication

- message authentication is concerned with:
 - protecting the integrity of a message
 - validating identity of originator
 - non-repudiation of origin (dispute resolution)
- will consider the security requirements
- then three alternative functions used:
 - message encryption
 - message authentication code (MAC)
 - hash function

Authentication

- Authentication is the process by which a person identity is proved
- It is slightly different from proving that a message has been sent from that sender (digital signature)
- No biometric information, only exchanged messages
→ authentication protocols (ap)
- ap 1.0



Copyright © 2005 Pearson
Addison Wesley All
rights reserved

♦ Protocol ap1.0 and a failure scenario

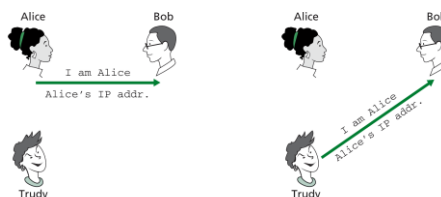
Antonio Della Selva

isti information science and technology institute

23/39

Authentication

- IP address could be used
- IP datagrams with artificial IP can be constructed if we can access to kernel of OS
- This approach is known as IP spoofing



Copyright © 2005 Pearson
Addison Wesley All
rights reserved

♦ Protocol ap2.0 and a failure scenario

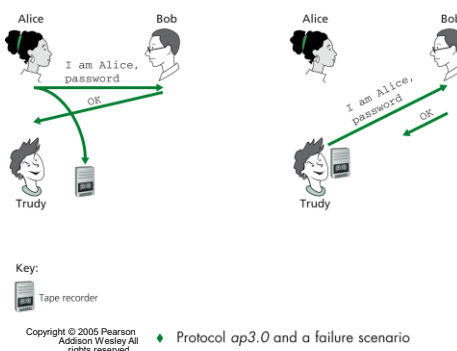
Antonio Della Selva

isti information science and technology institute

24/39

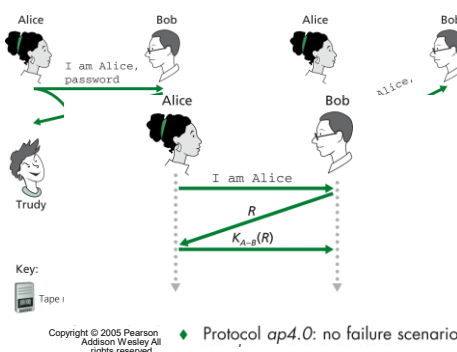
Authentication

- Password approach (PIN in bank-devices or login in OS)
- Not secure: Trudy can eavesdrop the password
- Telnet sends password in clear: if someone “sniffs” the LAN it can steal login passwords



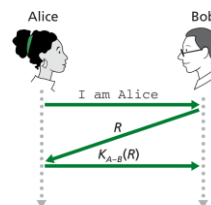
Authentication

- ap3.1: password can be encrypted (e.g. using a symmetric key)
- This can avoid the password theft, but doesn't solve the authentication
- Playback attack: the encrypted key can be registered and Trudy can use it to claim of being Alice
- We are again in situation of ap3.0



Authentication

- The problem in ap3.1 is that the same password is used multiple times
- It should be new every new authentication
- Alice and Bob could agree on a sequence of passwords or agree on a generation algorithm
- A more general approach:
 - Nonce: a number used by the protocol only once
 - Alice sends "I'm Alice"
 - Bob chooses a nonce R and sends it to Alice
 - Alice sends $K_{A-B}(R)$ (symmetric cryptography)
 - Bob decrypts the message: if nonce is the one he sent Alice is authenticated

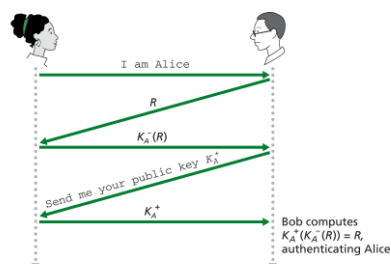


Copyright © 2005 Pearson
Addison Wesley All
rights reserved

♦ Protocol ap4.0: no failure scenario

Authentication

- ap5.0 obtains the same result as ap4.0 using public key
- Alice sends "I'm Alice"
- Bob choose R
- Alice encodes R with her private key k_A^- (she only knows her private key)
- Bob computes $k_A^+(k_A^-(R)) = R$

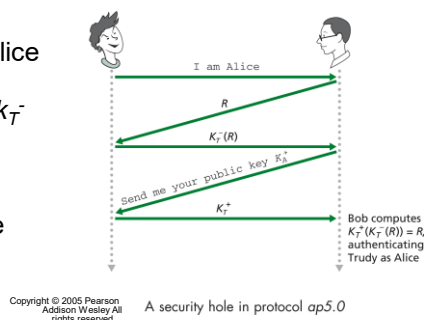


Copyright © 2005
Pearson
Addison Wesley
All rights
reserved

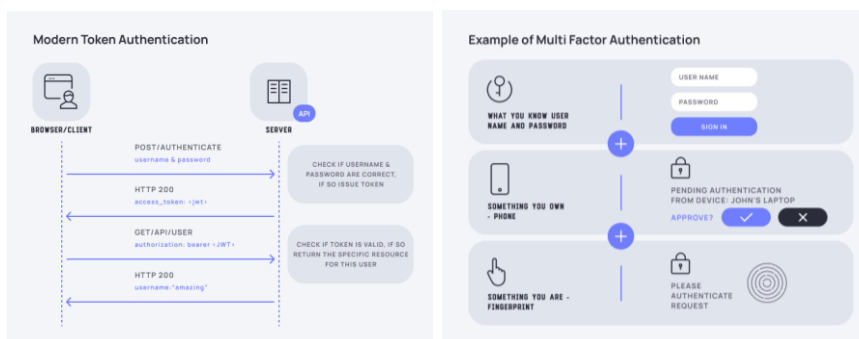
Protocol ap5.0 working correctly

Authentication

- Is ap5.0 as secure as ap4.0 ? Remember that Bob needs to know Alice's public key
- If Trudy sends "I'm Alice"
- Bob chooses a nonce R and sends it to Alice but Trudy intercepts the message
- Trudy can use his private key to crypt R : $k_T^-(R)$
- Bob cannot know if that string of bit represents $k_T^-(R)$ or $k_A^-(R)$
- Bob asks to Alice her public key (really he could find it in her web site)
- Trudy intercepts and sends k_{T+}
- Bob computes $k_T^+(k_T^-(R)) = R$
- and authenticates Trudy as Alice
- ap5.0 is as much reliable as the public key distribution (fortunately there are secure methods for key distribution)



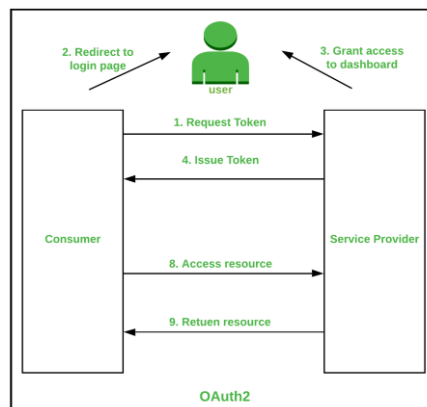
Types of Authentication





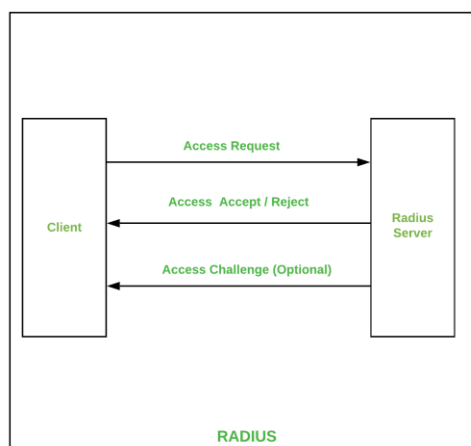
OAuth2

- Pro
 - It is a simple protocol and is easy to implement.
 - It provides server-side authorization of code.
- Cons
 - It is vulnerable to manage different sets of code.
 - It shows serious effects on sites connected to another affected system.



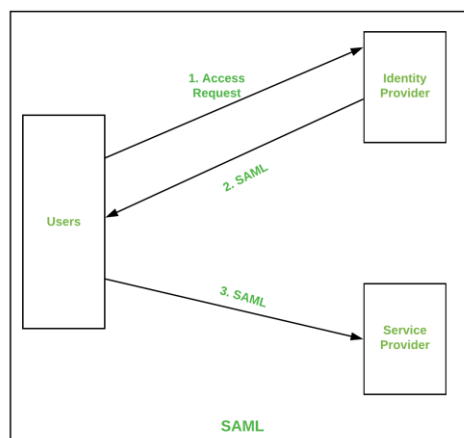
RADIUS

- Pro:
 - It is a great mechanism for providing multiple access for Admins.
 - It provides a unique identity to each user in a session.
- Cons:
 - Initial implementation for this mechanism is hard on hardware.
 - It has a variety of models that may require a special team which is cost consuming.



SAML

- Pro:
 - It reduced the administrative costs for the end-users.
 - It provides a single sign-in for authenticating across service providers.
- Cons:
 - It is dependent on the identity provider.
 - All the data is managed in a single XML format.

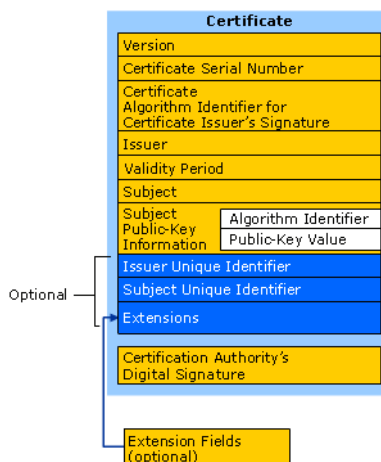


Digital Certification

- A digital certificate is a file or electronic password that proves the authenticity as well as confidentiality of a device or user, since it associates a public key with a specific entity.
- Another common use of digital certificates is to confirm the authenticity of a website to a web browser, which is also known as a secure sockets layer or SSL certificate.

Digital Certificate

- A digital certificate contains identifiable information.
- It also contains a copy of a public key from the certificate holder, which needs to be matched to a corresponding private key to verify it is real.



Certificate Authorities

- A public key certificate is issued by certificate authorities (CAs), which sign certificates to verify the identity of the requesting device or user.
- The CAs are neutral organizations that can manage certificates from issuing, revoking, and distribution.

Certificates and formats

- **Root certificate:** the top-level certificate.
- **Personal certificate:** Identifies a person and includes a digitally signed version of the person's name, organization, and public key
- **Self-signed certificate:** These certificates won't be trusted by the browsers of external users, but internal systems may be configured to trust the internal CA.
- Distinguished encoding rules (**DER**)
- Privacy enhanced mail (**PEM**)
- Personal information exchange (**PFX**): Commonly in windows systems
- **.cer**

Types of Certificate

- **SSL/TLS Certificate:** a TLS/SSL certificate sits on a server to ensure communication with its clients is private and encrypted
 - Domain Validated
 - Organization Validated
 - Extended Validated
- **Code Signing Certificate:** a code signing certificate is used to confirm the authenticity of software or files downloaded through the internet
- **Client Certificate:** a client certificate is a digital ID that identifies an individual user to other user or machine

Features of Digital Certificates

- **Authenticity:** They make sure that users messages will always reach their intended recipient
- **Security:** Digital certificates encrypt internal and external communications to prevent attackers from intercepting and stealing sensitive data.
- **Scalability:** They are highly scalable, which means they can easily be issued, revoked, and renewed in seconds
- **Reliability:** Only publicly trusted CAs can issue digital certificates.
- **Public Trust:** They confirm that a website is genuine and that documents are authentic